

AWS IAM Access Control Lab

Least Privilege Access Design for S3 and IAM

Field	Value
Project Name	Sec Cloud IAM Access Control Lab
Prepared By	Nhat Minh Nguyen
S3 Bucket	sec-iam-lab-nhatminh-2026
Date	2026-07-02

Table of Contents

1. Executive Summary
2. Project Objectives and Scope
3. AWS Security Baseline
4. Lab Architecture and Resource Setup
5. IAM Design
6. Policy Implementation
7. Test Plan and Evidence
8. Findings and Lessons Learned
9. Cleanup Plan
10. References

1. Executive Summary

This project implements a controlled AWS Identity and Access Management (IAM) lab for a fictional company named MiniSec Cloud. The goal is to design and validate least-privilege permissions for different job responsibilities using IAM groups, IAM users, and Amazon S3 resources.

The lab separates access between Developers, Interns, and Security Auditors. Developers are allowed to read and upload files only inside the dev/ prefix. Interns are allowed to read files inside dev/ but cannot upload or delete objects. Security Auditors are allowed to view IAM and S3 configuration, but cannot modify resources or read object contents.

The project demonstrates that AccessDenied results are not always failures. When a request is expected to be denied, the denial is evidence that the policy is enforcing the intended boundary.

Role / Principal	Intended Access	Security Goal
dev-user	Read and upload only in dev/	Limit developers to development files only.
intern-user	Read only in dev/	Prevent interns from changing or deleting data.
auditor-user	View IAM/S3 configuration only	Allow audit visibility without administrative power.
root/admin	Account administration only	Avoid using root/admin for normal lab tests.

2. Project Objectives and Scope

2.1 Objectives

- Create an S3 bucket with separated prefixes for dev, prod, app configuration, and logs.
- Create IAM groups and users that represent different work responsibilities.
- Attach customer-managed IAM policies to groups rather than assigning permissions directly to individual users.
- Test Allow and Deny outcomes for each user.
- Document evidence with screenshots and a test matrix.
- Practice least privilege by granting only the permissions required for each role.

2.2 Scope

In scope: IAM users, IAM groups, customer-managed identity-based policies, S3 bucket and object-level permissions, and console-based verification.

Out of scope for this phase: production workloads, real company data, access keys, automation with Terraform, CloudTrail investigation, and IAM Identity Center integration.

3. AWS Security Baseline

Before testing IAM users, the root account and lab environment should follow a basic security baseline.

Control	Expected Configuration	Evidence Placeholder
Root MFA	MFA enabled for the AWS account root user.	screenshots/root-mfa-enabled.png
Root access keys	No root access keys created or active.	screenshots/root-no-access-keys.png
S3 public access	Block all public access enabled for the lab bucket.	screenshots/s3-block-public-access.png
Object ownership	ACLs disabled where possible; access controlled through IAM policies.	screenshots/s3-object-ownership.png

My security credentials

Root userInfo

The root user has access to all AWS resources in this account, and we recommend following [best practices](#). To learn more about the types of AWS credentials and how they're used, see [AWS Security Credentials](#) in AWS General Reference

Account details

Account name

Email address

AWS account ID

Canonical user ID

Actions

Multi-factor authentication (MFA) (1)

Remove

Resync

Assign MFA device

Use MFA to increase the security of your AWS environment. Signing in with MFA requires an authentication code from an MFA device. Each user can have a maximum of 8 MFA devices assigned. [Learn more](#)

Type	Identifier	Certifications	Created on
☐ Passkeys and security keys			Thu Jul 02 2026

Access keys (0)

Create access key

Use access keys to send programmatic calls to AWS from the AWS CLI, AWS Tools for PowerShell, AWS SDKs, or direct AWS API calls. You can have a maximum of two access keys (active or inactive) at a time. [Learn more](#)

Access key ID	Created on	Access key last used	Region last used	Service last used	Status
No access keys					
As a best practice, avoid using long-term credentials like access keys. Instead, use tools which provide short term credentials. Learn more					
Create access key					

Block public access (bucket settings)

Edit

Public access is granted to buckets and objects through access control lists (ACLs), bucket policies, access point policies, or all. In order to ensure that public access to all your S3 buckets and objects is blocked, turn on Block all public access. These settings apply only to this bucket and its access points. AWS recommends that you turn on Block all public access, but before applying any of these settings, ensure that your applications will work correctly without public access. If you require some level of public access to your buckets or objects within, you can customize the individual settings below to suit your specific storage use cases. [Learn more](#)

Block all public access

On

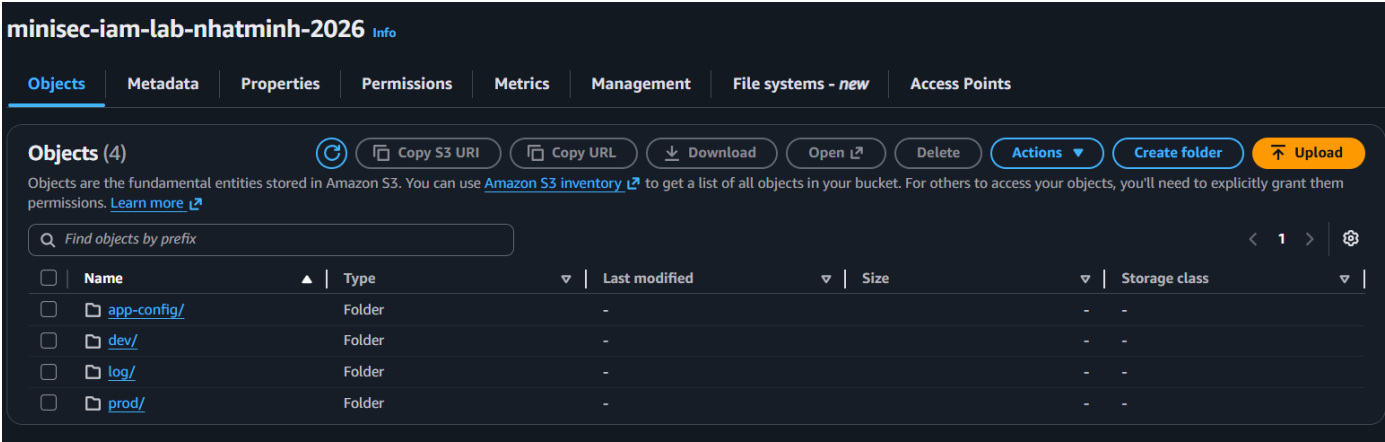
Individual Block Public Access settings for this bucket

4. Lab Architecture and Resource Setup

4.1 S3 Resource Layout

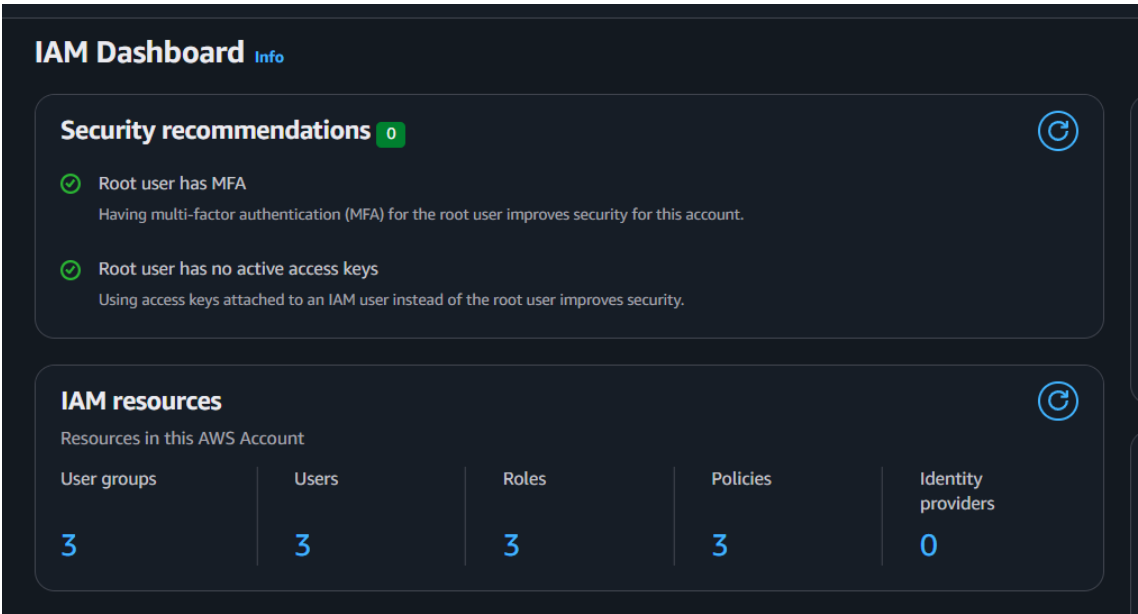
The lab uses one S3 bucket with multiple prefixes. In S3, folders shown in the console are object key prefixes.

```
s3://minisec-iam-lab-nhatminh-2026/
├── dev/
│   └── dev.txt
├── prod/
│   └── prod.txt
├── app-config/
│   └── config.json
├── logs/
│   └── event.log
```



4.2 IAM Identity Layout

Group	User	Policy	Purpose
Developers	dev-user	SecDeveloperPolicy	Read/write only in dev/.
Interns	intern-user	SecInternReadOnlyPolicy	Read only in dev/.
SecurityAuditors	auditor-user	SecSecurityAuditorPolicy	View IAM/S3 configuration only.



5. IAM Design

5.1 Access Model

Principal	dev/	prod/	app-config/	logs/	IAM Console	Bucket Admin
dev-user	Read / Upload	Deny	Deny	Deny	Deny	Deny
intern-user	Read only	Deny	Deny	Deny	Deny	Deny
auditor-user	List only / no object read	List only / no object read	List only / no object read	List only / no object read	View only	Deny modification

5.2 Policy Logic

The design uses identity-based policies attached to IAM groups. Each user inherits permissions from the group membership.

The Developer and Intern policies include console support permissions so the users can navigate the S3 console. Object-level permissions are restricted to the dev/ prefix.

Explicit Deny statements are used for dangerous actions such as deleting objects, deleting buckets, editing bucket policy, and changing ACLs. Explicit Deny takes priority over Allow in IAM evaluation.

6. Policy Implementation

6.1 SecDeveloperPolicy

Purpose: Allow developers to read and upload objects only inside dev/. Deny destructive or administrative S3 actions.

SecDeveloperPolicy Info

Allows developers to read and upload objects only inside the dev prefix of the IAM lab S3 bucket.

Policy details

Type
Customer managed

Creation time
July 02, 2026, 12:59 (UTC+07:00)

Edited time
July 02, 2026, 12:59 (UTC+07:00)

ARN

Permissions
Entities attached
Tags
Policy versions (1)
Last Accessed

Permissions defined in this policy Info

Copy
Edit
Summary
JSON

Permissions defined in this policy document specify which actions are allowed or denied. To define permissions for an IAM identity (user, user group, or role), attach a policy to it

```

1  {
2    "Version": "2012-10-17",
3    "Statement": [
4      {
5        "Sid": "ConsoleSupportForS3",
6        "Effect": "Allow",
7        "Action": [
8          "s3:ListAllMyBuckets",
9          "s3:GetBucketLocation"
10       ],
11       "Resource": "*"
12     },
13     {
14       "Sid": "ListLabBucket",
15       "Effect": "Allow",
16       "Action": "s3:ListBucket",
17       "Resource": "arn:aws:s3:::minisec-iam-lab-nhatminh-2026"
18     },
19     {
20       "Sid": "ReadWriteDevFolderOnly",
21       "Effect": "Allow",
22       "Action": [
23         "s3:GetObject",
24         "s3:PutObject"
25       ],

```

Prepared by: Nhat Minh Nguyen | Sec Cloud IAM Lab

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ConsoleSupportForS3",
      "Effect": "Allow",
      "Action": [
        "s3:ListAllMyBuckets",
        "s3:GetBucketLocation"
      ],
      "Resource": "*"
    },
    {
      "Sid": "ListLabBucket",
      "Effect": "Allow",
      "Action": "s3:ListBucket",
      "Resource": "arn:aws:s3:::minisec-iam-lab-nhatminh-2026"
    },
    {
      "Sid": "ReadWriteDevFolderOnly",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject",
        "s3:PutObject"
      ],
      "Resource": "arn:aws:s3:::minisec-iam-lab-nhatminh-2026/dev/*"
    },
    {
      "Sid": "DenyDangerousS3Actions",
      "Effect": "Deny",
      "Action": [
        "s3:DeleteObject",
        "s3:DeleteBucket",
        "s3:PutBucketPolicy",
        "s3:DeleteBucketPolicy",
        "s3:PutBucketPublicAccessBlock",
        "s3:PutBucketAcl",
        "s3:PutObjectAcl"
      ],
      "Resource": [
        "arn:aws:s3:::minisec-iam-lab-nhatminh-2026",
        "arn:aws:s3:::minisec-iam-lab-nhatminh-2026/*"
      ]
    }
  ]
}
```

6.2 SecInternReadOnlyPolicy

Purpose: Allow interns to read objects inside dev/ only. Deny upload, delete, and bucket administration actions.

SecInternReadOnlyPolicy Info
Edit Delete

Allows interns to read objects only inside the dev prefix of the IAM lab S3 bucket.

Policy details

Type	Creation time	Edited time	ARN
Customer managed	July 02, 2026, 13:07 (UTC+07:00)	July 02, 2026, 13:07 (UTC+07:00)	[REDACTED]

Permissions
Entities attached
Tags
Policy versions (1)
Last Accessed

Permissions defined in this policy Info
Copy Edit Summary JSON

Permissions defined in this policy document specify which actions are allowed or denied. To define permissions for an IAM identity (user, user group, or role), attach a policy to it

```

1 {
2   "Version": "2012-10-17",
3   "Statement": [
4     {
5       "Sid": "ConsoleSupportForS3",
6       "Effect": "Allow",
7       "Action": [
8         "s3:ListAllMyBuckets",
9         "s3:GetBucketLocation"
10      ],
11      "Resource": "*"
12    },
13    {
14      "Sid": "ListLabBucket",
15      "Effect": "Allow",
16      "Action": "s3:ListBucket",
17      "Resource": "arn:aws:s3::minisec-iam-lab-nhatminh-2026"
18    },
19    {
20      "Sid": "ReadOnlyDevFolder",
21      "Effect": "Allow",
22      "Action": "s3:GetObject",
23      "Resource": "arn:aws:s3::minisec-iam-lab-nhatminh-2026/dev/*"
24    },
25  ]
26 }
```

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ConsoleSupportForS3",
      "Effect": "Allow",
      "Action": [
        "s3:ListAllMyBuckets",
        "s3:GetBucketLocation"
      ],
      "Resource": "*"
    },
    {
      "Sid": "ListLabBucket",
      "Effect": "Allow",
      "Action": "s3:ListBucket",
      "Resource": "arn:aws:s3::minisec-iam-lab-nhatminh-2026"
    },
    {
      "Sid": "ReadOnlyDevFolder",
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3::minisec-iam-lab-nhatminh-2026/dev/*"
    },
    {
      "Sid": "DenyWriteAndDelete",
      "Effect": "Deny",
      "Action": [
        "s3:PutObject",
        "s3:DeleteObject",
        "s3:DeleteBucket",
        "s3:PutBucketPolicy",
        "s3:DeleteBucketPolicy",
        "s3:PutBucketPublicAccessBlock",
        "s3:PutBucketAcl",
        "s3:PutObjectAcl"
      ],
      "Resource": [
        "arn:aws:s3::minisec-iam-lab-nhatminh-2026",
        "arn:aws:s3::minisec-iam-lab-nhatminh-2026/*"
      ]
    }
  ]
}
```

6.3 SecSecurityAuditorPolicy

Purpose: Allow security auditors to view IAM and S3 configuration without modifying resources or reading S3 object content.

SecSecurityAuditorPolicy Info Edit Delete

Allows security auditors to view IAM and S3 configuration without modifying resources.

Policy details		Creation time	Edited time	ARN
Type	Customer managed	July 02, 2026, 13:11 (UTC+07:00)	July 02, 2026, 13:11 (UTC+07:00)	[REDACTED]

Permissions **Entities attached** **Tags** **Policy versions (1)** **Last Accessed**

Permissions defined in this policy Info Copy Edit Summary JSON

Permissions defined in this policy document specify which actions are allowed or denied. To define permissions for an IAM identity (user, user group, or role), attach a policy to it

```

1- {
2-   "Version": "2012-10-17",
3-   "Statement": [
4-     {
5-       "Sid": "ViewIAMConfiguration",
6-       "Effect": "Allow",
7-       "Action": [
8-         "iam:Get*",
9-         "iam:List*",
10-        "iam:GenerateCredentialReport",
11-        "iam:GetCredentialReport"
12-      ],
13-      "Resource": "*"
14-    },
15-    {
16-      "Sid": "ViewS3BucketConfiguration",
17-      "Effect": "Allow",
18-      "Action": [
19-        "s3:ListAllMyBuckets",
20-        "s3:GetBucketLocation",
21-        "s3:ListBucket",
22-        "s3:GetBucketPolicy",
23-        "s3:GetBucketAcl",
24-        "s3:GetBucketPublicAccessBlock",
25-        "s3:GetEncryptionConfiguration",

```

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ViewIAMConfiguration",
      "Effect": "Allow",
      "Action": [
        "iam:Get*",
        "iam:List*",
        "iam:GenerateCredentialReport",
        "iam:GetCredentialReport"
      ],
      "Resource": "*"
    },
    {
      "Sid": "S3ConsoleSupport",
      "Effect": "Allow",
      "Action": [
        "s3:ListAllMyBuckets",
        "s3:GetBucketLocation"
      ],
      "Resource": "*"
    },
    {
      "Sid": "ViewLabBucketConfiguration",
      "Effect": "Allow",
      "Action": [
        "s3:ListBucket",
        "s3:GetBucketPolicy",
        "s3:GetBucketAcl",
        "s3:GetBucketPublicAccessBlock",
        "s3:GetEncryptionConfiguration",
        "s3:GetBucketLogging",
        "s3:GetBucketVersioning",
        "s3:GetBucketTagging",
        "s3:GetBucketOwnershipControls"
      ],
      "Resource": "arn:aws:s3:::minisec-iam-lab-nhatminh-2026"
    },
    {
      "Sid": "DenyAllIAMAndS3Modification",
      "Effect": "Deny",
      "Action": [
        "iam:Create*",
        "iam:Update*",
        "iam>Delete*"

```



```

    "iam:Attach*",
    "iam:Detach*",
    "iam:Put*",
    "iam:Add*",
    "iam:Remove*",
    "s3:Put*",
    "s3:Delete*",
    "s3:CreateBucket"
  ],
  "Resource": "*"
}
]
}

```

7. Test Plan and Evidence

7.1 Test Method

Tests are performed by signing in as each IAM user in a separate private/incognito browser window. Each test records the expected result, actual result, and screenshot evidence.

Result labels: Pass means Expected and Actual match. For example, Expected Deny + Actual Deny = Pass.

7.2 Developer User Tests

Principal	Action	Resource	Expected	Actual	Result	Evidence
dev-user	s3:GetObject	dev/dev.txt	Allow	Allow	Pass	screenshots/dev-user-read-dev-allow.png
dev-user	s3:PutObject	dev/	Allow	ADD RESULT	ADD RESULT	screenshots/dev-user-upload-dev-allow.png
dev-user	s3:GetObject	prod/prod.txt	Deny	ADD RESULT	ADD RESULT	screenshots/dev-user-read-prod-denied.png
dev-user	s3:PutObject	prod/	Deny	ADD RESULT	ADD RESULT	screenshots/dev-user-upload-prod-denied.png
dev-user	iam:GetAccountSummary	IAM Dashboard	Deny	Deny	Pass	screenshots/dev-user-iam-access-denied.png
dev-user	s3:GetBucketVersioning	Bucket configuration	Deny	Deny	Pass	screenshots/dev-user-getbucketversioning-denied.png

AWS IAM Access Control Lab Report

[Alt+S]

Global

dev-use

New! IAM Outbound Identity Federation

You can now use short-lived JSON Web Tokens (JWTs) to securely authenticate your AWS workloads with third-party cloud providers, SaaS providers, and self-hosted applications.

Enable feature

IAM Dashboard

Info

Security recommendations

0

Access denied to iam:GetAccountSummary

You don't have permission to `iam:GetAccountSummary`. To request permission, copy the following text and send it to your AWS administrator. [Learn more about troubleshooting access denied errors.](#)

User: arn:aws:iam::[redacted]:user/dev-user

Action: iam:GetAccountSummary

On resource: *

Context: no identity-based policy allows the action

Diagnose with Amazon Q

Access denied to iam:ListMFADevices

You don't have permission to `iam:ListMFADevices`. To request permission, copy the following text and send it to your AWS administrator. [Learn more about troubleshooting access denied errors.](#)

User: arn:aws:iam::[redacted]:user/dev-user

Action: iam:ListMFADevices

On resource: *

Context: no identity-based policy allows the action

Diagnose with Amazon Q

Access denied to iam:ListAccessKeys

You don't have permission to `iam:ListAccessKeys`. To request permission, copy the following text and send it to your AWS administrator. [Learn more about troubleshooting access denied errors.](#)

User: arn:aws:iam::[redacted]:user/dev-user

Action: iam:ListAccessKeys

On resource: *

Context: no identity-based policy allows the action

Diagnose with Amazon Q

AWS Account

Access denied to iam:ListAccountAliases

You don't have permission to `iam:ListAccountAliases`. To request permission, copy the following text and send it to your AWS administrator. [Learn more about troubleshooting access denied errors.](#)

User: arn:aws:iam::[redacted]:user/dev-user

Action: iam:ListAccountAliases

On resource: *

Context: no identity-based policy allows the action

Diagnose with Amazon Q

Quick Links

My security credentials

Manage your access keys, multi-factor authentication (MFA) and other credentials.

[Alt+S]

United States (N. Virginia)

dev-use

minisec-iam-lab-nhatminh-2026

>

dev/

>

dev.txt

dev.txt

Info

Copy S3 URI

Download

Open

Object actions

Properties

Permissions

Versions

Object overview

Owner

[redacted]

AWS Region

US East (N. Virginia) us-east-1

Last modified

July 2, 2026, 12:45:37 (UTC+07:00)

Size

24.0 B

Type

txt

Key

dev/dev.txt

S3 URI

s3://minisec-iam-lab-nhatminh-2026/dev/dev.txt

Amazon Resource Name (ARN)

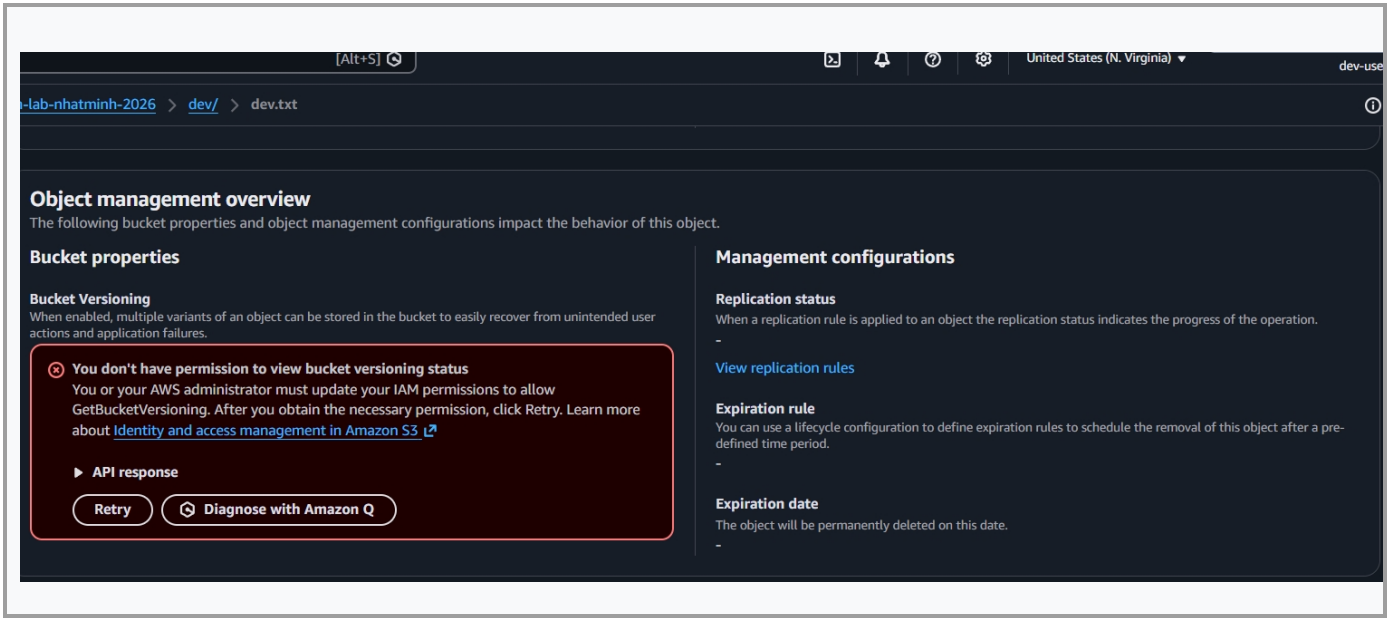
arn:aws:s3::minisec-iam-lab-nhatminh-2026/dev/dev.txt

Entity tag (Etag)

eef87266ae5774b7c16a8844edbe4091

Object URL

https://minisec-iam-lab-nhatminh-2026.s3.us-east-1.amazonaws.com/dev/dev.txt



7.3 Intern User Tests

Principal	Action	Resource	Expected	Actual	Result	Evidence
intern-user	s3:GetObject	dev/dev.txt	Allow	ADD RESULT	ADD RESULT	screenshots/intern-read-dev-allow.png
intern-user	s3:PutObject	dev/	Deny	ADD RESULT	ADD RESULT	screenshots/intern-upload-dev-deny.png
intern-user	s3:GetObject	prod/prod.txt	Deny	ADD RESULT	ADD RESULT	screenshots/intern-read-prod-deny.png
intern-user	s3>DeleteObject	dev/dev.txt	Deny	ADD RESULT	ADD RESULT	screenshots/intern-delete-dev-deny.png

The screenshot displays the AWS IAM console interface. At the top, the breadcrumb navigation shows 'iam-lab-nhatminh-2026' > 'dev/' > 'dev.txt'. The main header for 'dev.txt' includes tabs for 'Properties', 'Permissions', and 'Versions'. The 'Properties' tab is active, showing an 'Object overview' section. This section contains details such as the Owner (redacted), AWS Region (US East (N. Virginia) us-east-1), Last modified (July 2, 2026, 12:45:37 (UTC+07:00)), Size (24.0 B), Type (txt), and Key (dev/dev.txt). On the right side, it lists the S3 URI (s3://minisec-iam-lab-nhatminh-2026/dev/dev.txt), Amazon Resource Name (ARN) (arn:aws:s3::minisec-iam-lab-nhatminh-2026/dev/dev.txt), Entity tag (Etag) (redacted), and Object URL (https://minisec-iam-lab-nhatminh-2026.s3.us-east-1.amazonaws.com/dev/dev.txt).

Below the first screenshot, the second screenshot shows the 'minisec-iam-lab-nhatminh-2026' bucket overview. The 'Objects' tab is selected, displaying a list of objects. The list includes folders named 'app-config/', 'dev/', 'log/', and 'prod/'. The table has columns for Name, Type, Last modified, Size, and Storage class. The 'dev/' folder is highlighted.

7.4 Security Auditor User Tests

Principal	Action	Resource	Expected	Actual	Result	Evidence
auditor-user	iam:ListUsers	IAM Users page	Allow	ADD RESULT	ADD RESULT	screenshots/auditor-view-iam-users-allow.png
auditor-user	iam:CreateUser	IAM Create User page	Deny	ADD RESULT	ADD RESULT	screenshots/auditor-create-user-deny.png
auditor-user	s3:ListBucket	minisec-iam-lab-nhatminh-2026	Allow	ADD RESULT	ADD RESULT	screenshots/auditor-list-bucket-allow.png
auditor-user	s3:GetObject	dev/dev.txt	Deny	ADD RESULT	ADD RESULT	screenshots/auditor-getobject-deny.png
auditor-user	s3:PutObject	dev/	Deny	ADD RESULT	ADD RESULT	screenshots/auditor-upload-deny.png

[Alt+S]

Global

auditor-u

New! IAM Outbound Identity Federation

You can now use short-lived JSON Web Tokens (JWTs) to securely authenticate your AWS workloads with third-party cloud providers, SaaS providers, and self-hosted applications.

Enable feature

IAM Dashboard

Info

Security recommendations

1

✓ Root user has MFA

Having multi-factor authentication (MFA) for the root user improves security for this account.

⚠ Add MFA for yourself

Add multi-factor authentication (MFA) for yourself to improve security for this account.

Add MFA

✓ Your user, auditor-user, does not have any active access keys that have been unused for more than a year.

Deactivating or deleting unused access keys improves security.

AWS Account

Account ID

Account Alias

Create

Sign-in URL for IAM users in this account

IAM resources

Resources in this AWS Account

User groups

3

Users

3

Roles

3

Policies

3

Identity providers

0

Quick Links

My security credentials

Manage your access keys, multi-factor authentication (MFA) and other credentials.

User was not created.
User: arn:aws:iam::[redacted]:user/auditor-user is not authorized to perform: iam:CreateUser on resource: arn:aws:iam::[redacted]:user/user-1 with an explicit deny in an identity-based policy: arn:aws:iam::[redacted]:policy/SecSecurityAuditorPolicy

Review and create
Review your choices. After you create the user, you can view and download the autogenerated password, if enabled.

User details

User name	Console password type	Require password reset
user-1	Custom password	Yes

Permissions summary

Name	Type	Used as
IAMUserChangePassword	AWS managed	Permissions policy
Interns	Group	Permissions group

Tags - optional
Tags are key-value pairs you can add to AWS resources to help identify, organize, or search for resources. Choose any tags you want to associate with this user.
No tags associated with the resource.
[Add new tag](#)
You can add up to 50 more tags.

Cancel Previous **Create user**

This XML file does not appear to have any style information associated with it. The document tree is shown below.

```
<?xml version="1.0"?>
<Error>
  <script id="nimlmejbmnecnagbmbahmbaddhjbecg"/>
  <script/>
  <script/>
  <Code>AccessDenied</Code>
  <Message>User: arn:aws:iam::[redacted]:user/auditor-user is not authorized to perform: s3:GetObject on resource: "arn:aws:s3:::minisec-iam-lab-nhatminh-2026/dev/dev.txt" because no identity-based policy allows the s3:GetObject action</Message>
  <RequestId>[redacted]</RequestId>
  <HostId>[redacted]</HostId>
</Error>
```

Select text only

8. Findings and Lessons Learned

8.1 Key Findings

- Group-based permissions reduce management complexity and make role boundaries easier to review.
- The Developer policy allowed object-level work in dev/ while denying IAM and bucket administration access.
- AccessDenied messages from AWS Console can appear when the console tries to call extra APIs such as GetBucketVersioning. These should be interpreted based on the expected permission model.
- Attaching a policy to the wrong group can break least privilege even when the JSON policy itself is correct.
- Explicit Deny is useful for blocking dangerous actions even if another policy later grants broader access.

8.2 Security Lesson Learned

IAM permissions should be assigned based on job responsibility, not convenience. A developer does not need full S3 access or IAM access to perform development tasks. By limiting access to only the dev/ prefix, the policy reduces the risk of accidental or malicious access to production data.

Expected Deny results should be documented as successful test cases. They show that the permission boundary is working as designed.

8.3 Mistake Found During Implementation

During setup, SecDeveloperPolicy was accidentally attached to all groups. This was corrected by removing the policy from Interns and SecurityAuditors and attaching separate policies based on each role. This highlights the importance of checking principal-to-policy mapping, not only the JSON policy content.

9. Cleanup Plan

After completing the lab and screenshots, clean up unused resources to reduce risk and avoid unnecessary charges.

- Delete uploaded test objects if they are no longer needed.
- Delete the S3 bucket after saving the report evidence.
- Detach and delete customer-managed policies created for the lab.
- Delete IAM users and groups created for the lab.
- Do not leave access keys or unused console users active.

10. References

- [1] AWS IAM Introduction: <https://docs.aws.amazon.com/IAM/latest/UserGuide/introduction.html>
- [2] AWS IAM Security Best Practices: <https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html>
- [3] Root User Best Practices: <https://docs.aws.amazon.com/IAM/latest/UserGuide/root-user-best-practices.html>
- [4] Multi-factor Authentication for AWS Account Root User: <https://docs.aws.amazon.com/IAM/latest/UserGuide/enable-mfa-for-root.html>
- [5] IAM Policies and Permissions: https://docs.aws.amazon.com/IAM/latest/UserGuide/access_policies.html
- [6] S3 Identity-based Policy Examples: <https://docs.aws.amazon.com/AmazonS3/latest/userguide/example-policies-s3.html>
- [7] Amazon S3 Actions, Resources, and Condition Keys: https://docs.aws.amazon.com/service-authorization/latest/reference/list_amazons3.html
- [8] Required Permissions for Amazon S3 API Operations: <https://docs.aws.amazon.com/AmazonS3/latest/userguide/using-with-s3-policy-actions.html>